

Práctica de laboratorio

507-EGSánchez-ISOP406_ResetPasswWIN.docx

Objetivo de la práctica

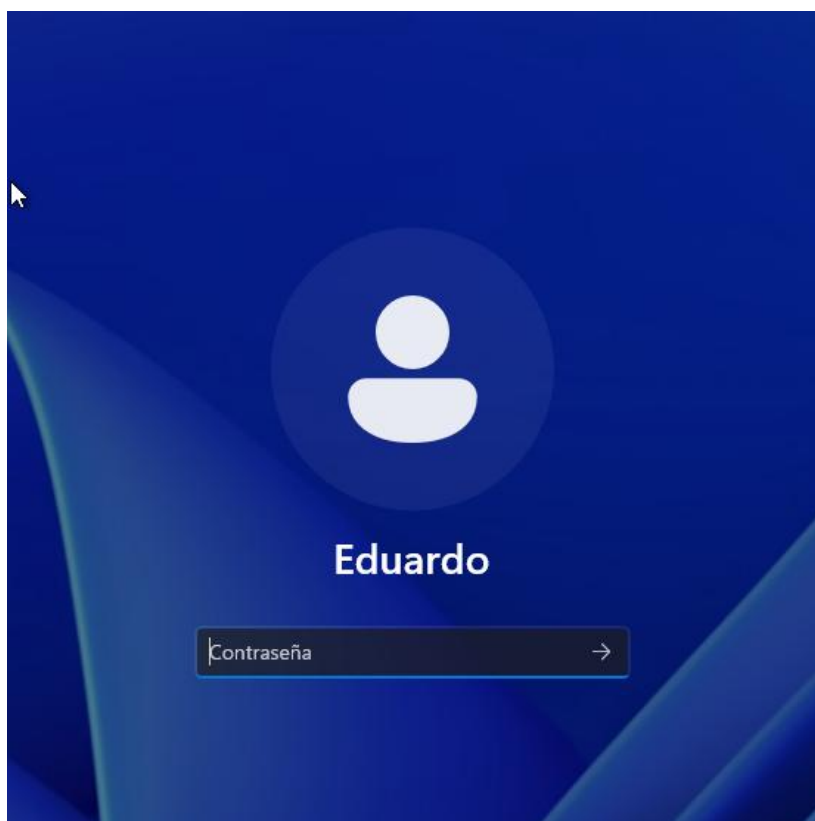
Crear una máquina virtual LiveCD sin disco propio y que tome el disco del sistema Windows, gestionar el paquete chntpw en un sistema Linux, hackear la contraseña de Windows y hacer pruebas de conexión al sistema Windows (entrada al sistema como administrador).

Inventario de material necesario

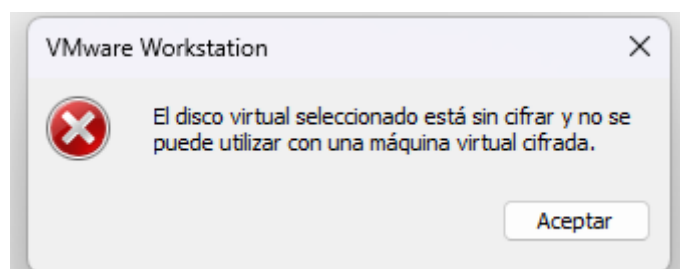
- Un sistema Windows funcional en el que conocemos el nombre del administrador, pero no la contraseña
- Un LiveCD de Ubuntu

Ejecución

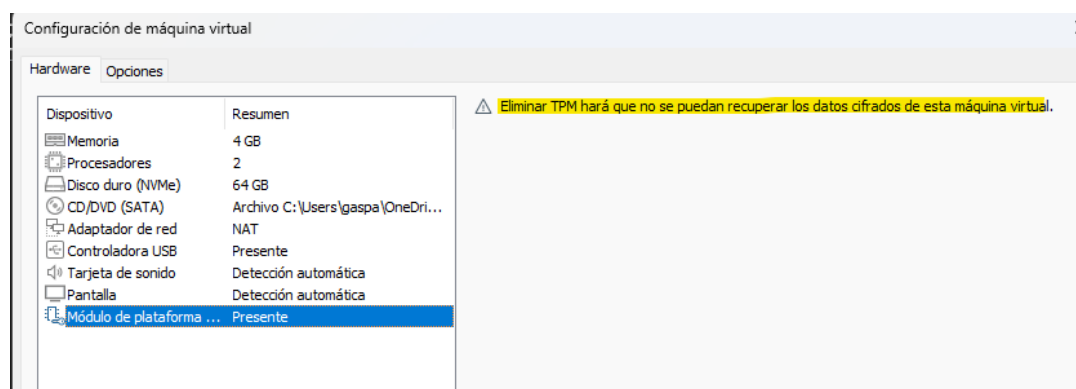
Instalamos Windows11 en una máquina y seguimos los pasos hasta que nos deje entrar en el sistema operativo e introducir la contraseña:

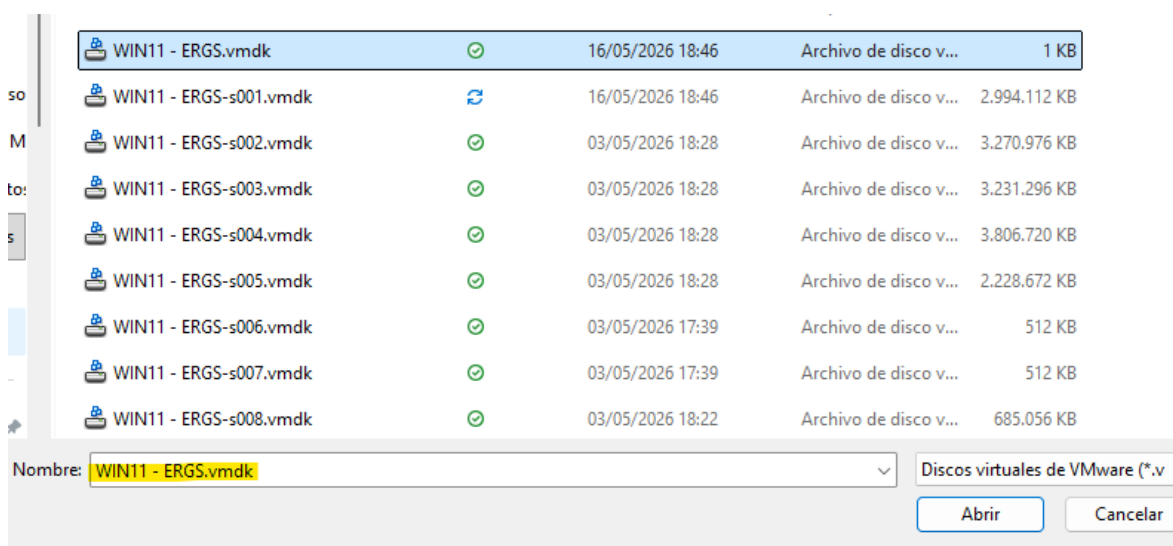


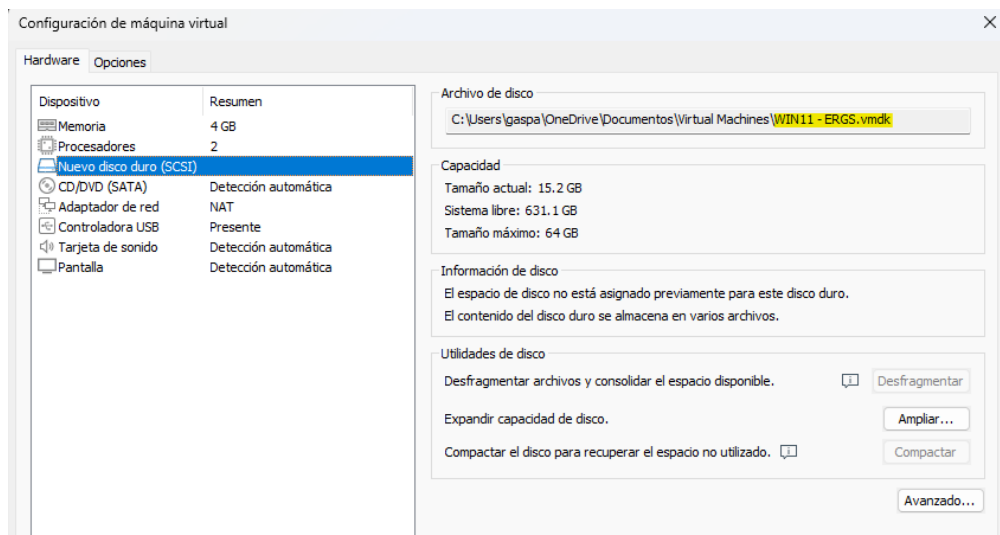
Para poder hackear esta contraseña desde Ubuntu, creamos otra máquina virtual y en la configuración de la máquina quitaremos el disco que se crea por defecto para añadir uno preexistente (el de Windows11). Nos aseguramos de que las máquinas no están cifradas, ya que nos saldrá el siguiente mensaje:



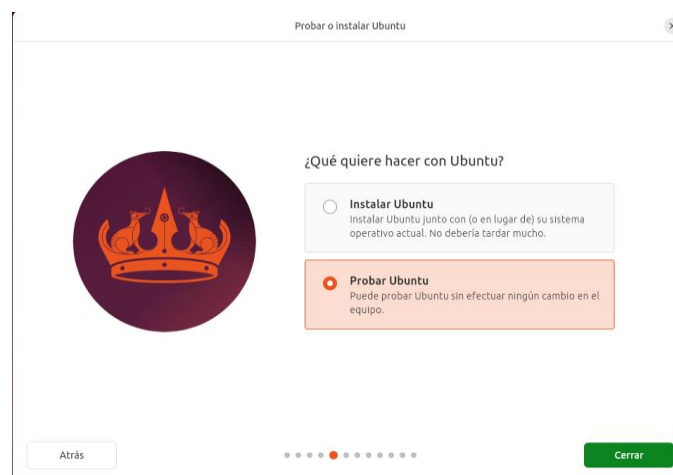
Para eliminar el cifrado, nos vamos a los ajustes de la máquina. En la pestaña de Hardware, eliminamos “Módulo de plataforma temporal” TPM para luego en la pestaña de Opciones deshabilitar el acceso cifrado. A continuación añadimos el disco preexistente cuya ruta es la misma que la del disco de Windows:







Ahora podremos entrar en Ubuntu (No lo instalaremos ya que no nos hará falta para esta práctica). Una vez dentro, podemos entrar al gestor de ficheros de Ubuntu para revisar que tenemos instalado nuestro disco de 64GB que pertenece a Windows11. En este caso, me aseguro de ello usando en la terminal el comando “lsblk”. La ruta del disco que buscamos es “/dev/sda3”:



```
ubuntu@ubuntu:~$ lsblk
NAME        MAJ:MIN RM  SIZE RO TYPE MOUNTPOINTS
loop0       7:0      0   1.7G  1 loop /rofs
loop1       7:1      0 536.4M  1 loop
loop2       7:2      0   946M  1 loop
loop3       7:3      0    4K   1 loop /snap/bare/5
loop4       7:4      0    74M  1 loop /snap/core22/2292
loop5       7:5      0 531.4M  1 loop /snap/gnome-42-2204/247
loop6       7:6      0   18.5M  1 loop /snap/firmware-updater/210
loop7       7:7      0 251.7M  1 loop /snap/firefox/7766
loop8       7:8      0   91.7M  1 loop /snap/gtk-common-themes/1535
loop9       7:9      0   10.8M  1 loop /snap/snap-store/1270
loop10      7:10     0   48.1M  1 loop /snap/snapd/25935
loop11      7:11     0    576K  1 loop /snap/snapd-desktop-integration/343
loop12      7:12     0   112.6M  1 loop /snap/ubuntu-desktop-bootstrap/494
loop13      7:13     0  226.6M  1 loop /snap/thunderbird/959
sda         8:0      0   64G   0 disk
├─sda1      8:1      0  200M   0 part
├─sda2      8:2      0    16M   0 part
└─sda3      8:3      0    63G   0 part
sda4       8:4      0  793M   0 part
sr0        11:0     1   6.2G   0 rom  /cdrom
ubuntu@ubuntu:~$ sudo mkdir /mnt/windows
```

Ahora instalamos el paquete “chntpw” de forma automática a la vez que hacemos un update. Después podremos entrar en el cd a la ruta del archivo SAM (No sale en las capturas, pero ejecutamos “cd /mnt/windows/Windows/System32/config”) y escribimos en la terminal: “sudo chntpw -u nombre_usuario_Win SAM”.

```
ubuntu@ubuntu:~$ sudo apt-get update && sudo apt-get install chntpw -y
Ign:1 cdrom://Ubuntu 24.04.4 LTS _Noble Numbat_ - Release amd64 (20260210) noble
InRelease
Hit:2 cdrom://Ubuntu 24.04.4 LTS _Noble Numbat_ - Release amd64 (20260210) noble
Release
Get:3 http://security.ubuntu.com/ubuntu noble-security InRelease [126 kB]
Get:5 http://security.ubuntu.com/ubuntu noble-security/main i386 Packages [413 k
B]
Get:6 http://security.ubuntu.com/ubuntu noble-security/main amd64 Packages [1668
kB]
Get:7 http://security.ubuntu.com/ubuntu noble-security/main Translation-en [264
kB]
Get:8 http://security.ubuntu.com/ubuntu noble-security/main amd64 Components [21
```

```
ubuntu@ubuntu:/mnt/windows/Windows/System32/config$ sudo chntpw -u Eduardo SAM
chntpw version 1.00 140201, (c) Petter N Hagen
Hive <SAM> name (from header): <\SystemRoot\System32\Config\SAM>
ROOT KEY at offset: 0x001020 * Subkey indexing type is: 686c <lh>
File size 65536 [10000] bytes, containing 7 pages (+ 1 headerpage)
Used for data: 283/29008 blocks/bytes, unused: 24/15824 blocks/bytes.

===== USER EDIT =====

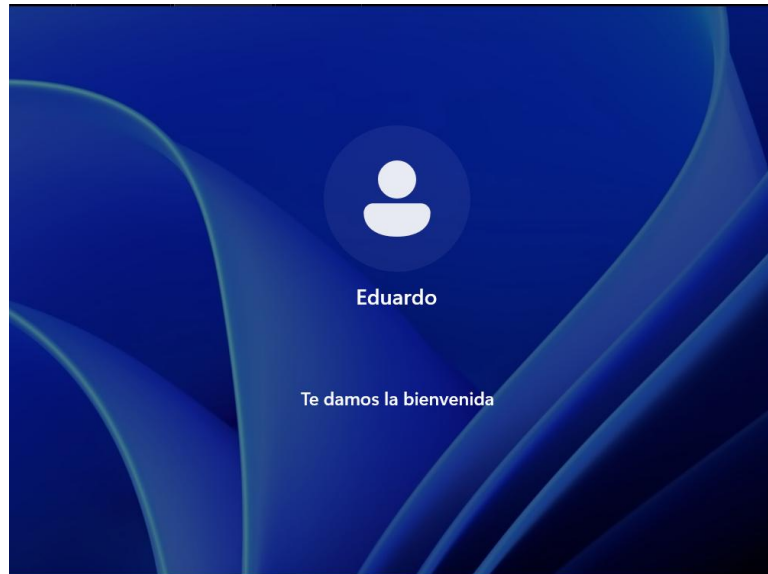
RID      : 1001 [03e9]
Username: Eduardo
fullname:
comment  :
homedir  :

00000220 = Administradores (which has 2 members)

Account bits: 0x0214 =
[ ] Disabled          | [ ] Homedir req.    | [X] Passwd not req. |
[ ] Temp. duplicate   | [X] Normal account  | [ ] NMS account     |
[ ] Domain trust ac   | [ ] Wks trust act.  | [ ] Srv trust act   |
[X] Pwd don't expir   | [ ] Auto lockout    | [ ] (unknown 0x08)  |
[ ] (unknown 0x10)    | [ ] (unknown 0x20)  | [ ] (unknown 0x40)  |
```

En esta sección tendremos que presionar las teclas “1” para seleccionar la opción “Clear (blank) user password”, que borra la contraseña por completo, “q” para salir e “y” para confirmar y escribir los datos

Una vez hecho esto apagamos por completo la máquina y encendemos la de Windows. Al entrar nos daremos cuenta de que, al haber eliminado o “crackeado” la contraseña en Ubuntu, nos presentamos automáticamente en el escritorio sin ninguna medida de seguridad previa.



Consideraciones finales

La práctica me ha parecido muy interesante y útil para comprender la vulnerabilidad de las contraseñas locales cuando se tiene acceso físico al disco duro. Durante el proceso se aprende a interactuar con sistemas de archivos desde un LiveCD de Linux, a localizar la base de datos de credenciales de Windows en el archivo SAM y a resolver conflictos de propiedad de recursos en VMware.

Durante el transcurso de la práctica me atasque en tres puntos clave: primero, al intentar añadir el disco en caliente a un Ubuntu existente generando un conflicto en VMware; segundo, cuando la interfaz gráfica de Ubuntu retuvo el disco en segundo plano en el punto loop uno; y tercero, cuando Windows11 dejó firmas de hibernación rápida y metadatos de BitLocker que denegaban el acceso. Lo más difícil fue romper estos bloqueos de montaje en la partición sda tres, algo que resolví abandonando el entorno gráfico y recurriendo a la terminal para identificar el volumen con lsblk, matar los procesos aún activos con fuser y forzar el acceso limpio mediante los parámetros avanzados de la herramienta ntfs-3g.

Solucionados esos puntos, la práctica ha resultado sencilla e interesante para estudiar más acerca de las formas en las que se puede “hackear” sistemas en entornos de laboratorio.